Key Management

- public-key encryption helps address key distribution problems
- have two aspects of this:
  - distribution of public keys
  - use of public-key encryption to distribute secret keys

3

Distribution of Public Keys

- can be considered as using one of:
  - public announcement
  - publicly available directory
  - public-key authority
  - public-key certificates

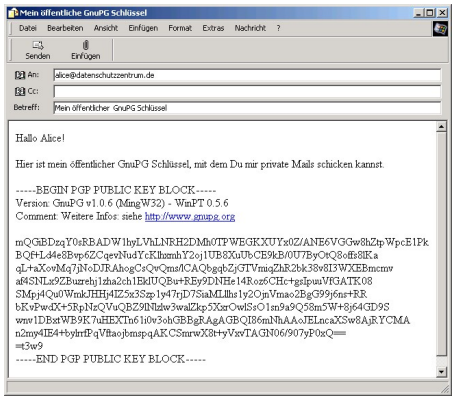
4

Public Announcement

- users distribute public keys to recipients or broadcast to community at large
  - eg. append PGP keys to email messages or post to news groups or email list
- major weakness is forgery
  - anyone can create a key claiming to be someone else and broadcast it
  - until forgery is discovered can masquerade as claimed user

5

PGP



6

Publicly Available Directory

- can obtain greater security by registering keys with a public directory
- directory must be trusted with properties:
  - contains {name,public-key} entries
  - participants register securely with directory
  - participants can replace key at any time
  - directory is periodically published
  - directory can be accessed electronically
- still vulnerable to tampering or forgery

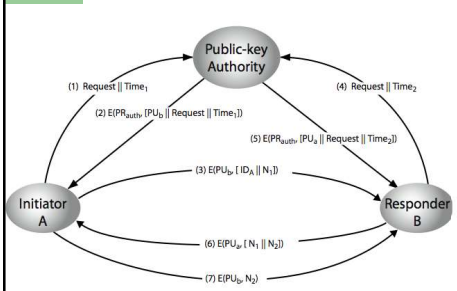
7

Public-Key Authority

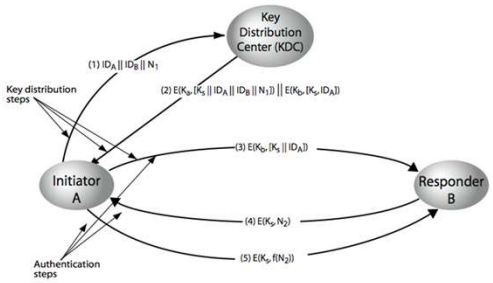
- improve security by tightening control over distribution of keys from directory
- has properties of directory
- and requires users to know public key for the directory
- then users interact with directory to obtain any desired public key securely
  - does require real-time access to directory when keys are needed

8

Public-Key Authority



Public key



Session key

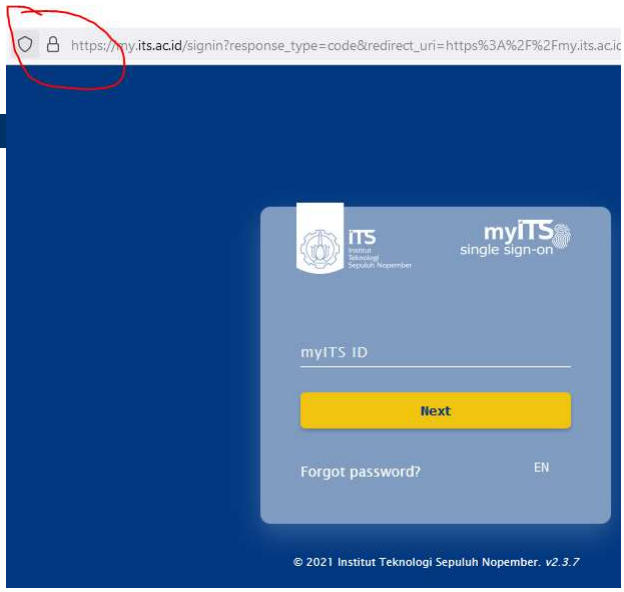
9

Public-Key Certificates

- certificates allow key exchange without real-time access to public-key authority
- a certificate binds **identity** to **public key**
  - usually with other info such as period of validity, rights of use etc
- with all contents **signed** by a trusted Public-Key or Certificate Authority (CA)
- can be verified by anyone who knows the public-key authorities public-key

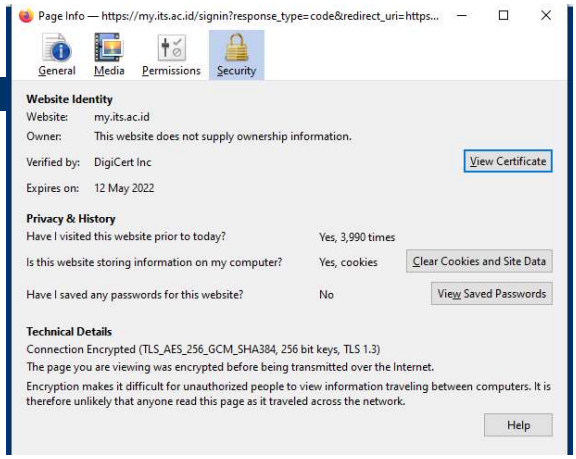
10

Certificate



11

Certificate



12

Certificate

Firefox about:certificate?cert=MIIGsTCCBZmgAwIBAgIQB8GYmNS1xCMFI24b4P6q1DANBgkqhkiG9w0BAQsFADB

Certificate

*.its.ac.id | DigiCert SHA2 Secure Server CA | DigiCert Global Root

Subject Name

Country	ID
State/Province	Jawa Timur
Locality	Surabaya
Organization	Institut Teknologi Sepuluh Nopember
Common Name	*.its.ac.id

Issuer Name

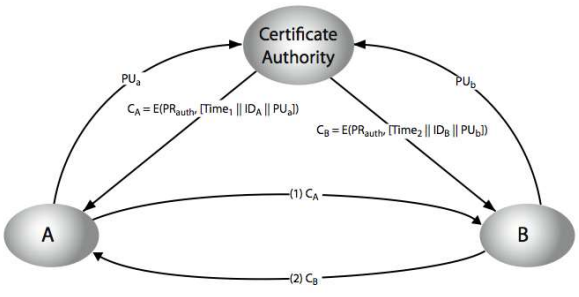
Country	US
Organization	DigiCert Inc
Common Name	DigiCert SHA2 Secure Server CA

Validity

Not Before	Mon, 06 Apr 2020 00:00:00 GMT
Not After	Thu, 12 May 2022 12:00:00 GMT

13

Public-Key Certificates



14

Public-Key Distribution of Secret Keys

- use previous methods to obtain public-key
- can use for secrecy or authentication
- but public-key algorithms are slow
- so usually want to use private-key encryption to protect message contents
- hence need a session key
- have several alternatives for negotiating a suitable session

15

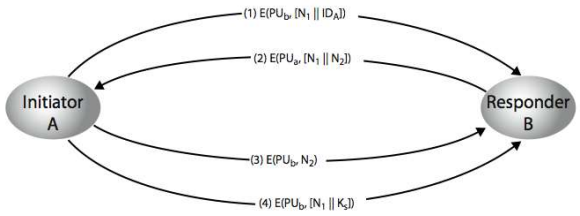
Simple Secret Key Distribution

- proposed by Merkle in 1979
  - A generates a new temporary public key pair
  - A sends B the public key and their identity
  - B generates a session key K sends it to A encrypted using the supplied public key
  - A decrypts the session key and both use
- problem is that an opponent can intercept and impersonate both halves of protocol

16

Public-Key Distribution of Secret Keys

- if have securely exchanged public-keys:



Note: (4) from B to A
(4) E(PU_a,[N_1||K_s])

17

Hybrid Key Distribution

- retain use of private-key KDC
- shares secret master key with each user
- distributes session key using master key
- public-key used to distribute master keys
  - especially useful with widely distributed users
- rationale
  - performance
  - backward compatibility

18

Diffie-Hellman Key Exchange

- first public-key type scheme proposed
- by Diffie & Hellman in 1976 along with the exposition of public key concepts
  - note: now know that Williamson (UK CESG) secretly proposed the concept in 1970
- is a practical method for public exchange of a secret key
- used in a number of commercial products

19

Diffie-Hellman Key Exchange

- a public-key distribution scheme
  - cannot be used to exchange an arbitrary message
  - rather it can establish a common key
  - known only to the two participants
- value of key depends on the participants (and their private and public key information)
- based on exponentiation in a finite (Galois) field (modulo a prime or a polynomial) - easy
- security relies on the difficulty of computing discrete logarithms (similar to factoring) – hard

20

Diffie-Hellman Setup

- all users agree on global parameters:
  - large prime integer or polynomial q
  - a being a primitive root mod q
- each user (eg. A) generates their key
  - chooses a secret key (number): $x_A < q$
  - compute their **public key**: $y_A = a^{x_A} \bmod q$
- each user makes public that key y_A

21

Primitive root

q=7; a=3				q=7; a=2		
c	a^c	a^c mod q		c	a^c	a^c mod q
0	1	1		0	1	1
1	3	3		1	2	2
2	9	2		2	4	4
3	27	6		3	8	1
4	81	4		4	16	2
5	243	5		5	32	4

22

DLP - Example

- If $a^b = c$, then $\log_a c = b$
- Example:
  - $2^3 = 8 \Leftrightarrow \log_2 8 = 3$
  - $10^3 = 1000 \Leftrightarrow \log_{10} 1000 = 3$
- Computing a^b and $\log_a c$ are both easy for real numbers.
- However, when working with field such as (Zp,mod), it is easy to calculate $c = a^b \bmod p$, but given *c*, *a* and *p* it is very difficult to find *b*.
- Given an integer *n* it is hard to find two integers *p*, *q* such that $n = p \bullet q$ (factorisation problem as in RSA)

23

Diffie-Hellman Key Exchange

- shared session key for users A & B is K_{AB}:

$$K_{AB} = a^{x_A . x_B} \bmod q$$
$$= y_A^{x_B} \bmod q \quad \text{(which } \mathbf{B} \text{ can compute)}$$
$$= y_B^{x_A} \bmod q \quad \text{(which } \mathbf{A} \text{ can compute)}$$

- K_{AB} is used as session key in private-key encryption scheme between Alice and Bob
- if Alice and Bob subsequently communicate, they will have the **same** key as before, unless they choose new public-keys
- attacker needs an x, must solve discrete log

24

Diffie-Hellman Example

- users Alice & Bob who wish to swap keys:
- agree on prime $q=353$ and $a=3$
- select random secret keys:
  - A chooses $x_A=97$, B chooses $x_B=233$
- compute respective public keys:
  - $y_A=3^{97} \mod 353 = 40$ (Alice)
  - $y_B=3^{233} \mod 353 = 248$ (Bob)
- compute shared session key as:
  - $K_{AB}= y_B^{x_A} \mod 353 = 248^{97} = 160$ (Alice)
  - $K_{AB}= y_A^{x_B} \mod 353 = 40^{233} = 160$ (Bob)

25

Summary

- have considered:
  - distribution of public keys
  - public-key distribution of secret keys
  - Diffie-Hellman key exchange

26